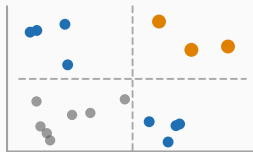


Risque opérationnel et résilience

Chapitre 2 : La gouvernance du risque



Avant de commencer

Le cadre prudentiel du risque

La gouvernance par comités

Les trois lignes de défense

Appétit et culture du risque

Synthèse

Avant de commencer

Pourquoi ce chapitre ?

Après avoir défini le risque opérationnel, ce chapitre pose les fondations de sa gestion : le cadre réglementaire prudentiel qui l'encadre, la gouvernance par comités et le modèle des trois lignes de défense, et les deux piliers complémentaires que sont l'appétit pour le risque et la culture du risque.

Le cadre prudentiel du risque

Pilier 1, Pilier 2, Pilier 3

La réglementation du risque opérationnel est apparue avec Bâle II en 2004, qui a introduit trois piliers prudentiels. Le **Pilier 1** fixe le capital réglementaire minimal pour couvrir les risques de crédit, de marché et opérationnel. Le **Pilier 2** permet au régulateur d'imposer un supplément de capital (« add-on ») propre au profil de risque de l'établissement, non couvert par le Pilier 1. Le **Pilier 3** impose des obligations de publication périodique destinées à renforcer la discipline de marché.

Le seul risque où la gestion elle-même est une exigence réglementaire de Pilier 1

Le risque opérationnel est le seul type de risque pour lequel des principes de gestion figurent dans la réglementation de Pilier 1 elle-même : une bonne gestion du risque opérationnel n'est donc pas optionnelle, elle est obligatoire, car aucun montant de capital ne peut à lui seul compenser l'absence de gestion saine face à des défaillances opérationnelles.

Les Principes pour la saine gestion du risque opérationnel

La dernière révision des Principes pour la saine gestion du risque opérationnel (RPSMOR), publiée en mars 2021, comprend 12 principes organisés autour de la gouvernance (culture portée par le conseil, cadre de gestion proportionné, revue et approbation par le conseil, appétit et tolérance au risque), du management (rôle de la direction générale, identification et évaluation exhaustives, gestion du changement, surveillance régulière), du contrôle (environnement de contrôle robuste, gestion des technologies de l'information, plans de continuité d'activité) et de la transparence (publication de l'approche et des expositions).

Le calcul du capital de Pilier 1

De l'AMA à l'approche standard (SA)

Jusqu'en 2023, les établissements choisissaient entre trois approches : l'**approche indicateur de base** (15 % du produit brut moyen sur trois ans), l'**approche standard** (variante pondérée par ligne d'activité), et les **approches de mesure avancées** (AMA), fondées sur des modèles internes validés par le régulateur, calibrés à un intervalle de confiance de 99,9 % sur un an. Depuis janvier 2023, une **approche standardisée** unique (SA) s'applique à tous : le capital requis est le produit d'une composante d'indicateur d'activité (BIC) et d'un multiplicateur de pertes internes (ILM).

La mécanique du BIC et de l'ILM

L'indicateur d'activité (BI) agrège trois composantes : la composante d'intérêts, de loyers et de dividendes (ILDC), la composante de services (SC), et la composante financière (FC, résultat net des activités de négociation et de bancarisation). Le pourcentage marginal appliqué au BI croît avec la taille de l'établissement (12 % en dessous de 1 milliard d'euros, jusqu'à 18 % au-delà de 30 milliards), reconnaissant que le risque opérationnel croît plus que proportionnellement avec la taille. Le multiplicateur ILM ajuste ensuite ce montant à la hausse ou à la baisse selon que l'historique de pertes de l'établissement sur dix ans dépasse ou non son indicateur d'activité.

Une auto-évaluation validée par le régulateur

Le Pilier 2 est une évaluation qualitative complémentaire, laissant le régulateur ajuster à la hausse le capital calculé en Pilier 1 lorsque le profil de risque de l'établissement le justifie. Selon les juridictions, cette auto-évaluation porte des noms différents : le processus d'évaluation interne de l'adéquation du capital (ICAAP) en Europe, intégré à la procédure de revue et d'évaluation prudentielle (SREP); l'évaluation interne des risques et de la solvabilité (ORSA) dans l'assurance; et, aux États-Unis, le processus de revue prudentielle général, incluant le programme CCAR pour les grandes banques.

Un paysage réglementaire fragmenté mais coordonné par Bâle

Aux États-Unis, la Réserve fédérale, l'OCC et la FDIC se partagent la supervision bancaire. En Europe, le Mécanisme de surveillance unique (BCE et autorités nationales) et l'Autorité bancaire européenne (EBA) coordonnent la réglementation prudentielle. Au Royaume-Uni, la PRA (stabilité financière) et la FCA (protection des consommateurs) se partagent les responsabilités depuis la crise de 2007-2008. En Asie, la MAS à Singapour, l'APRA en Australie, la CBIRC en Chine et la HKMA à Hong Kong jouent des rôles équivalents. Le BCBS influence fortement le contenu de ces réglementations nationales, qui restent néanmoins distinctes.

L'absence de preuve est une preuve d'absence

Aux yeux des régulateurs, un cadre de gestion du risque opérationnel ne doit pas être un simple exercice de conformité sur le papier : il doit être *utilisé*, et l'établissement doit pouvoir le démontrer (le « test d'usage »). La règle non écrite des superviseurs est sans appel : si une organisation ne peut produire aucune preuve qu'une pratique existe, la conclusion prudentielle est que cette pratique n'existe pas.

Six questions typiques d'un examen prudentiel

Un examen prudentiel typique porte sur l'exhaustivité des rapports d'incidents (y compris les quasi-incidents), la robustesse et la cohérence des auto-évaluations des risques et des contrôles, l'indépendance et la fraîcheur des indicateurs de risque, le réalisme et l'exhaustivité des scénarios, la complétude de la couverture du dispositif, et l'adéquation du reporting au niveau de décision auquel il est destiné.

La gouvernance par comités

Une pyramide de comités

Du comité local au comité du conseil

La gouvernance du risque opérationnel s'organise en pyramide : à la base, des comités par activité ou zone géographique surveillent le profil de risque local et remontent les enjeux significatifs; au niveau intermédiaire, le comité groupe de risque opérationnel consolide l'information vers le comité de direction et le comité risques du conseil; au sommet, le comité risques créé par le conseil d'administration supervise l'ensemble du risque opérationnel et fait des recommandations au conseil plénier.

Les termes de référence, socle de la gouvernance documentaire

Chaque comité fonctionne sur la base de « termes de référence » (ou charte) précisant son rôle, sa composition, ses responsabilités et la fréquence de ses réunions. Les décisions et leurs motivations doivent être consignées dans des comptes rendus — c'est la preuve documentaire de bonne gouvernance attendue par les superviseurs.

Fixer l'appétit pour le risque, superviser sa mise en œuvre

Le conseil d'administration porte la responsabilité ultime de l'administration générale de l'établissement, y compris de la gestion des risques. Il lui revient de déterminer la nature et l'ampleur des risques significatifs que l'établissement est disposé à prendre, de valider le cadre de gestion du risque opérationnel, d'en assurer la révision périodique, et d'obtenir l'assurance que la direction générale le met effectivement en œuvre.

Les trois lignes de défense

Trois rôles bien distincts

Ligne 1, ligne 2, ligne 3

La **première ligne de défense** — les propriétaires du risque — regroupe le personnel opérationnel et commercial, responsable de l'identification, de l'évaluation et de la maîtrise quotidienne des risques inhérents à son activité. La **deuxième ligne** est la fonction indépendante de gestion du risque opérationnel (CORF), chargée de développer le cadre de gestion des risques et d'exercer une supervision et un rôle de challenge sur la première ligne. La **troisième ligne** est l'audit interne, qui fournit une assurance indépendante sur l'ensemble du dispositif, y compris sur la fonction risque elle-même.

Ce qui définit une ligne, ce sont les responsabilités, pas le nom du département

Ce qui détermine si une fonction appartient à la première, à la deuxième ou à la troisième ligne n'est pas l'intitulé du département, mais les rôles et responsabilités qui lui sont attribués. De nombreuses fonctions — juridique, ressources humaines, sécurité informatique — exercent en réalité des rôles hybrides, mêlant première et deuxième ligne selon les tâches concernées, ce qui exige une documentation précise de la délimitation des rôles.

Le débat sur l'indépendance de la deuxième ligne

La relation entre première et deuxième ligne reste le point le plus débattu du modèle : une indépendance trop stricte de la deuxième ligne pose la question de sa redondance avec l'audit interne, tandis qu'une implication trop poussée dans les activités opérationnelles compromet sa capacité de challenge. La deuxième ligne possède la méthodologie; la première ligne possède les risques — c'est la formule qui résume le partage des rôles.

Appétit et culture du risque

Structurer un appétit pour le risque actionnable

Aligné à la stratégie, mesuré par des indicateurs

L'appétit pour le risque doit articuler les motivations de prendre ou d'éviter certains types de risque, s'aligner sur les objectifs stratégiques de l'établissement, et se décliner en limites d'exposition, en exigences minimales de contrôle, et en seuils de fréquence et de sévérité des incidents tolérés — surveillés par des indicateurs clés de risque (« KRI d'appétit »).

Un exemple de déclaration d'appétit pour le risque de conduite

Une banque peut afficher une tolérance minimale aux manquements de conduite commerciale, tout en acceptant que des incidents isolés surviennent dans un réseau de vente de plusieurs milliers d'agents — à condition qu'ils touchent moins de 0,2 % de la force de vente, soient corrigés rapidement, et que les clients affectés soient pleinement indemnisés dans des délais fixés (réponse sous 24 heures, résolution sous 5 jours ouvrés).

Le ton donné par la direction, la culture du « no-blame »

La culture du risque relève du « ton donné par le sommet » : les dirigeants fixent le ton de l'organisation par leur propre conduite. Une culture du « pas de blâme injustifié » (« no unnecessary blame ») encourage la remontée spontanée des incidents et des quasi-incidents, sans crainte de sanction disproportionnée pour celui qui les signale — condition essentielle pour que les leçons des erreurs profitent à l'ensemble de l'organisation.

Des signes concrets d'une bonne culture du risque

Trois signes récurrents trahissent une culture du risque saine : l'application des mêmes règles à tous, sans exception pour les cadres dirigeants; l'escalade rapide des problèmes, avant qu'ils ne s'aggravent; et le partage des leçons apprises entre entités, comme l'a fait une grande banque d'investissement française après la perte de 4,9 milliards d'euros de Jérôme Kerviel, en diffusant dans tout le groupe des retours d'expérience anonymisés sur des incidents passés.

Synthèse

Synthèse du chapitre

Le risque opérationnel est encadré par les trois piliers de Bâle II — capital minimal (Pilier 1, désormais calculé selon l'approche standardisée unique BIC × ILM), supplément qualitatif (Pilier 2, ICAAP/SREP), et transparence (Pilier 3) — et par les douze principes de la RPSMOR, qui font de sa gestion une obligation, non une option. La gouvernance s'organise en pyramide de comités sous la responsabilité ultime du conseil d'administration, et repose sur le modèle des trois lignes de défense : les propriétaires du risque en première ligne, la fonction indépendante de risque opérationnel en deuxième ligne, l'audit interne en troisième ligne. Un appétit pour le risque clairement articulé et une culture du risque fondée sur le no-blame et l'escalade rapide complètent ce dispositif — sans eux, aucun cadre réglementaire, aussi bien conçu soit-il, ne produit une gestion du risque réellement effective.